

INFORME DE PENTESTING

Actividad A08 — Hacking Ético

Cliente: INSECUR S.A. | Laboratorio: TryHackMe

Seguridad Aplicada a Sistemas de Información

Licenciatura en Sistemas de Información — Facultad de Informática y Diseño

Docente: Ing. Rodrigo Atilio Elgueta

Contratista: Falanti Mateo

Username TryHackMe: mateofalantiuch

1. Datos generales

Cliente	INSECUR S.A.
Contratista (alumno/a)	Falanti Mateo
DNI	44406358
Username TryHackMe	mateofalantiuch
Email institucional	mateofalantiuch@gmail.com
Sala de elección (Nivel 2)	Vulniversity
Branch en GitHub	Falanti-Mateo
Fecha de inicio	05/10/2026
Fecha de cierre	07/10/2026

Salas trabajadas

Nivel	Sala	Tipo	Estado
Núcleo	Pentesting Fundamentals	Teórica	[Completada]
Núcleo	Basic Pentesting	Práctica	Completada
Elección	Vulniversity	Práctica	Completada

2. Pre-pentesting

2.1 Alcance del trabajo

Dentro del alcance: únicamente las máquinas virtuales de TryHackMe asignadas en esta actividad: Basic Pentesting y Vulniversity, accedidas mediante la VPN oficial de la plataforma y solo contra la IP asignada a cada sesión.

Fuera del alcance: cualquier otro sistema, red o servicio, incluida la infraestructura de TryHackMe ajena a las máquinas desplegadas, la red de la facultad y cualquier sistema real o de terceros.

2.2 Reglas de enfrentamiento (ROE)

- Objetivos permitidos: solo la IP asignada por TryHackMe durante la sesión activa.
- Técnicas permitidas: escaneo, enumeración, explotación y escalada de privilegios propias de cada sala.
- Técnicas restringidas: fuerza bruta (Hydra) solo si la sala lo requiere, con límites de hilos y wordlist.
- Técnicas prohibidas: denegación de servicio y ataques contra la plataforma, otros usuarios o sistemas fuera de alcance.
- Límites de tráfico: escaneos con tasas moderadas, sin saturar el objetivo.
- Ante un incidente: detener la actividad, documentar lo ocurrido e informar al docente.
- Datos sensibles: bitácoras revisadas para quitar secretos; flags reportadas solo como hash SHA-256.

2.3 Autorización

Declaro que cuento con autorización expresa de la cátedra de Seguridad Aplicada a Sistemas de Información (FID-UCH) para realizar pruebas de penetración sobre los entornos de laboratorio de TryHackMe indicados en la guía de la Actividad A08, con fines exclusivamente académicos.

2.4 Metodología utilizada

Marco adoptado: PTES (Penetration Testing Execution Standard).

Justificación: PTES describe una intervención de pentesting de principio a fin, desde los acuerdos previos con el cliente hasta la entrega del informe, lo que coincide con la estructura de esta actividad: documentación previa, durante y posterior a la intervención, más un protocolo de contingencia. Sus fases se aplicaron directamente a las máquinas de TryHackMe, asociando cada hallazgo a la fase en la que fue descubierto. Como PTES no define una escala de severidad, se complementó con CVSS para estimar la criticidad de cada hallazgo y con categorías OWASP/CWE para clasificarlos.

Fase	Aplicación en este trabajo
Preenganche	Secciones de alcance, ROE y autorización de este informe
Reconocimiento y escaneo	Verificación de conectividad (ping) y descubrimiento de puertos, servicios y versiones con Nmap
Enumeración	Análisis del servicio web (comentarios HTML, Gobuster), del recurso SMB anónimo y confirmación de usuarios válidos por SSH
Explotación	Ataque de contraseñas con Hydra (rockyou.txt) contra el usuario jan; intento de explotación de PwnKit (CVE-2021-4034); bypass de un filtro de extensiones (lista negra) y subida de una webshell en Vulniversity, confirmando ejecución remota de código (RCE) como www-data
Postexplotación	Enumeración local y con LinPEAS; obtención y crackeo con John the Ripper de la clave SSH privada del usuario kay; en Vulniversity, escalada de privilegios a root explotando el bit SUID del binario /bin/systemctl
Reporte	Hallazgos, recomendaciones y protocolo de contingencia

3. Hallazgos por fase

3.1 Pentesting Fundamentals

Sala teórica: no genera hallazgos. Aporta el marco metodológico de la sección 2. Evidencia de finalización: evidencias/general/captura de completado pentesting fundamentals.png

3.2 Basic Pentesting

Hallazgo H-01

ID del hallazgo	H-01
Sala	Basic Pentesting
Fase	☒ Reconocimiento ☐ Escaneo ☐ Enumeración ☐ Explotación ☐ Postexplotación
Descripción	El servidor web (puerto 80) muestra una página de "mantenimiento" que contiene un comentario HTML visible en el código fuente, indicando la existencia de una sección de "dev notes". Un escaneo de directorios con Gobuster confirmó un directorio /development/ con listado de Apache habilitado, exponiendo dos archivos de texto (dev.txt y j.txt) con información interna del equipo: versión de un componente instalado (Apache Struts 2.5.12) y una conversación entre empleados donde se menciona que la contraseña de un usuario fue "crackeada fácilmente".
Componente afectado	Apache httpd 2.4.41, directorio /development/ (puerto 80)
Categoría (OWASP / CWE)	A01:2021 – Broken Access Control / CWE-200 (Information Exposure)
CVE (si aplica)	No aplica
CVSS estimado	☐ Bajo ☒ Medio ☐ Alto ☐ Crítico Puntaje: 5.3
Evidencia (captura / comando)	curl / gobuster; evidencias/reconocimiento/archivo staff.png (nota: pendiente captura específica de dev.txt/j.txt)
Herramienta utilizada	curl, Gobuster
Impacto en la Tríada CIA	☒ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Eliminar comentarios de desarrollo del HTML en producción, deshabilitar el listado de directorios de Apache (Options -Indexes) y retirar archivos de notas internas del document root público.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

Hallazgo H-02

ID del hallazgo	H-02
Sala	Basic Pentesting
Fase	☒ Reconocimiento ☐ Enumeración ☐ Escaneo ☐ Explotación ☐ Postexplotación
Descripción	El servicio Samba (puertos 139/445) expone un recurso compartido llamado "Anonymous" accesible sin autenticación. Dentro de ese recurso se encontró el archivo staff.txt, un aviso interno que menciona explícitamente el nombre de usuario "Jan" del sistema. Esta información, sumada a la nota hallada en el hallazgo H-01, permitió confirmar "jan" como usuario válido del sistema vía SSH (el servidor solicitó contraseña en lugar de rechazar el usuario).
Componente afectado	Samba smbd 4 (puertos 139/445), recurso compartido "Anonymous"
Categoría (OWASP / CWE)	A01:2021 – Broken Access Control / CWE-200 (Information Exposure)
CVE (si aplica)	No aplica
CVSS estimado	☐ Bajo ☒ Medio ☐ Alto ☐ Crítico Puntaje: 5.3
Evidencia (captura / comando)	smbclient -L / smbclient //.../Anonymous; evidencias/reconocimiento/reconocimiento_H-02.png
Herramienta utilizada	smbclient
Impacto en la Tríada CIA	☒ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Deshabilitar el acceso anónimo (guest) al recurso Samba, aplicar autenticación obligatoria y revisar periódicamente qué contenido se comparte sin control de acceso.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

Hallazgo H-03

ID del hallazgo	H-03
Sala	Basic Pentesting
Fase	☐ Reconocimiento ☐ Enumeración ☐ Escaneo ☒ Explotación ☐ Postexplotación
Descripción	A partir de la pista obtenida en los hallazgos anteriores (contraseña débil de un usuario), se realizó un ataque de diccionario con Hydra contra el servicio SSH utilizando el usuario "jan" y una wordlist derivada de rockyou.txt. El ataque encontró una contraseña válida en pocos minutos, confirmando una política de contraseñas débil. Con las credenciales obtenidas se logró acceso inicial por SSH como el usuario "jan", sin privilegios de administrador (sudo -l no mostró permisos).

Componente afectado	OpenSSH 8.2p1 (puerto 22), cuenta de usuario "jan"
Categoría (OWASP / CWE)	A07:2021 – Identification and Authentication Failures / CWE-521 (Weak Password Requirements)
CVE (si aplica)	No aplica
CVSS estimado	☐ Bajo ☐ Medio ☒ Alto ☐ Crítico Puntaje: 7.5
Evidencia (captura / comando)	hydra -l jan -P top1000.txt ...; evidencias/explotacion/password crackeado.png, evidencias/explotacion/reconocimiento_H-03.png, evidencias/explotacion/howami id uname dentro al ingresar con ssh.png
Herramienta utilizada	Hydra, rockyou.txt
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Forzar una política de contraseñas robusta (longitud mínima, complejidad), implementar autenticación por clave pública en lugar de contraseña, y limitar los intentos de login (fail2ban) para mitigar ataques de fuerza bruta.
Riesgo residual tras aplicar	☐ Bajo ☒ Medio ☐ Alto

Hallazgo H-04

ID del hallazgo	H-04
Sala	Basic Pentesting
Fase	☐ Reconocimiento ☐ Enumeración ☐ Escaneo ☐ Explotación ☒ Postexplotación
Descripción	Con acceso como "jan", se ejecutó LinPEAS para enumerar vectores de escalada de privilegios. Se identificó que el binario pkexec tiene el bit SUID activo y una versión (0.105) vulnerable a CVE-2021-4034 (PwnKit). Se intentó explotar la vulnerabilidad mediante un script público basado en condición de carrera, sin éxito tras varios intentos (la asignación de contraseña a la cuenta creada nunca se completó). Se descartó esta vía por limitaciones de tiempo, documentando el intento como parte del proceso.
Componente afectado	/usr/bin/pkexec (polkit 0.105), SUID root
Categoría (OWASP / CWE)	A06:2021 – Vulnerable and Outdated Components / CWE-78
CVE (si aplica)	CVE-2021-4034 (PwnKit)
CVSS estimado	☐ Bajo ☐ Medio ☐ Alto ☒ Crítico Puntaje: 7.8
Evidencia (captura / comando)	linpeas.sh tee linpeas_output.txt (salida parcial en bitácora, sin datos sensibles de AWS)

Herramienta utilizada	LinPEAS, script público CVE-2021-4034 (condición de carrera)
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☒ Disponibilidad
Salvaguarda propuesta	Actualizar polkit/pkexec a una versión parcheada ($\geq 0.105-26+$ según distribución) y aplicar las actualizaciones de seguridad de Ubuntu ESM disponibles para el sistema.
Riesgo residual tras aplicar	☐ Bajo ☒ Medio ☐ Alto

Hallazgo H-05

ID del hallazgo	H-05
Sala	Basic Pentesting
Fase	☐ Reconocimiento ☐ Enumeración ☐ Escaneo ☐ Explotación ☒ Postexplotación
Descripción	La enumeración con LinPEAS reveló que la clave SSH privada del usuario "kay" (/home/kay/.ssh/id_rsa) tiene permisos de lectura para otros usuarios del sistema (incluyendo "jan"). Se copió la clave y se crackeó su passphrase con John the Ripper (ssh2john + rockyou.txt), obteniendo acceso SSH como "kay", usuario con privilegios adicionales (grupos adm, sudo, lxd, entre otros) y con acceso al archivo pass.bak conteniendo la contraseña final del desafío.
Componente afectado	/home/kay/.ssh/id_rsa (permisos -rw-r--r--)
Categoría (OWASP / CWE)	A01:2021 – Broken Access Control / CWE-522 (Insufficiently Protected Credentials)
CVE (si aplica)	No aplica
CVSS estimado	☐ Bajo ☐ Medio ☐ Alto ☒ Crítico Puntaje: 9.1
Evidencia (captura / comando)	ls -la /home/kay/.ssh/; ssh2john + john; ssh -i id_rsa_kay kay@...; evidencias/post/obtencion del password de jhon.png, evidencias/post/Contraseña del archivo pass.bak.png, evidencias/post/final del room y hash de la contraseña.png
Herramienta utilizada	LinPEAS, ssh2john, John the Ripper (rockyou.txt)
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Restringir los permisos de archivos de claves privadas a solo su propietario (chmod 600), proteger las claves con passphrases robustas no presentes en diccionarios comunes, y auditar periódicamente los permisos de archivos sensibles en directorios home.
Riesgo residual tras aplicar	☐ Bajo ☒ Medio ☐ Alto

3.3 Vulniversity

Hallazgo H-06

ID del hallazgo	H-06
Sala	Vulniversity
Fase	☐ Reconocimiento ☐ Escaneo ☐ Enumeración ☒ Explotación ☐ Postexplotación
Descripción	El formulario de subida de archivos en /internal/index.php (puerto 3333) valida las extensiones mediante una lista negra, bloqueando .php y variantes comunes (.php3/4/5/7, .pht, .phar), pero no contempla la extensión .phtml. Se subió un archivo .phtml con código PHP (system(\$_GET["cmd"])) que el servidor interpretó y ejecutó, confirmando RCE como www-data. A partir de ahí se obtuvo una reverse shell completa hacia la máquina atacante.
Componente afectado	/internal/index.php y /internal/uploads/ (Apache 2.4.41, puerto 3333)
Categoría (OWASP / CWE)	A08:2021 — Software and Data Integrity Failures / CWE-434 (Unrestricted Upload of File with Dangerous Type)
CVE (si aplica)	No aplica
CVSS estimado	☐ Bajo ☐ Medio ☒ Alto ☐ Crítico Puntaje: 8.8
Evidencia (captura / comando)	curl / gobuster (upload) + reverse shell; evidencias/explotacion/formulario de subida de archivos si restriccion de tipo.png, evidencias/explotacion/gobuster encontro directorio no destinado a ser publico room3.png, evidencias/explotacion/reverse shell obtenida.png, evidencias/explotacion/flag de bill sacada del user.txt.png
Herramienta utilizada	curl, Gobuster, Netcat
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☒ Disponibilidad
Salvaguarda propuesta	Validar el tipo de archivo mediante lista blanca (no lista negra) y verificar el contenido real (magic bytes/MIME), no solo la extensión. Deshabilitar la ejecución de scripts en el directorio de uploads (por ejemplo, con php_admin_flag engine off) o servirlo desde un dominio/subdominio sin intérprete PHP.
Riesgo residual tras aplicar	☐ Bajo ☒ Medio ☐ Alto

Hallazgo H-07

ID del hallazgo	H-07
Sala	Vulniversity
Fase	☐ Reconocimiento ☐ Escaneo ☐ Enumeración ☐ Explotación ☒ Postexplotación
Descripción	Con acceso como www-data (obtenido en H-06), la enumeración local

	(find / -perm -4000) reveló que el binario /bin/systemctl tiene el bit SUID activo. Se explotó esta condición creando una unidad de servicio systemd en /dev/shm con un ExecStart que ejecuta comandos arbitrarios, registrándola (systemctl link) y habilitándola (systemctl enable --now). El servicio corrió con privilegios de root, permitiendo leer /root/root.txt y confirmar acceso total al sistema (uid=0).
Componente afectado	/bin/systemctl (SUID root)
Categoría (OWASP / CWE)	A01:2021 — Broken Access Control / CWE-250 (Execution with Unnecessary Privileges)
CVE (si aplica)	No aplica (misconfiguración local, no CVE pública)
CVSS estimado	☐ Bajo ☐ Medio ☒ Alto ☐ Crítico Puntaje: 7.8
Evidencia (captura / comando)	find SUID + systemctl link / enable --now; evidencias/post/flag de root.png
Herramienta utilizada	find, systemctl
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☒ Disponibilidad
Salvaguarda propuesta	Quitar el bit SUID de /bin/systemctl, ya que no es necesario para su funcionamiento habitual. Auditar periódicamente binarios con SUID innecesario (find / -perm -4000) y aplicar el principio de menor privilegio en la configuración del sistema.
Riesgo residual tras aplicar	☐ Bajo ☒ Medio ☐ Alto

4. Resumen ejecutivo de hallazgos

Severidad	Cantidad	ID de hallazgos
Crítico	2	H-04, H-05
Alto	3	H-03, H-06, H-07
Medio	2	H-01, H-02
Bajo	0	—
Total	7	

Conclusión general: la evaluación identificó una cadena de ataque completa, desde la exposición de información interna en la web y el recurso compartido de archivos, hasta el acceso total al servidor mediante contraseñas débiles y permisos de archivos mal configurados. Si bien no se requirieron vulnerabilidades sofisticadas, la combinación de fallas simples permitió comprometer el sistema por completo. Se recomienda priorizar el fortalecimiento de la política de contraseñas y la revisión de permisos de archivos sensibles. En la sala de elección (Vulniversity) se identificó una segunda cadena de ataque independiente: una falla de validación en la subida de archivos permitió ejecución remota de código, y una mala configuración local (binario SUID) permitió escalar directamente a root, reforzando la conclusión de que fallas de validación y de configuración, más que vulnerabilidades complejas, son las que habilitan el compromiso total de un sistema.

5. Post-pentesting: Recomendaciones

5.1 Recomendaciones técnicas (parches y configuraciones)

Prioridad	Hallazgo	Acción de remediación
1 - Crítica	H-05	Corregir permisos de /home/kay/.ssh/id_rsa a 600 y forzar passphrases robustas en todas las claves privadas
1 - Crítica	H-04	Actualizar polkit/pkexec a una versión parcheada de CVE-2021-4034
2 - Alta	H-03	Forzar política de contraseñas robustas y autenticación por clave pública en SSH; implementar fail2ban
1 - Crítica	H-07	Quitar el bit SUID de /bin/systemctl y auditar periódicamente binarios con SUID innecesario (find / -perm -4000)
2 - Alta	H-06	Validar las subidas de archivos con lista blanca y verificación de contenido real (magic bytes/MIME); deshabilitar la ejecución de scripts en el directorio de uploads

5.2 Recomendaciones administrativas (políticas y procesos)

- Establecer y auditar periódicamente una política de contraseñas robusta para todos los usuarios del sistema.
- Capacitar al personal sobre el manejo seguro de claves SSH y el riesgo de compartir información interna en servidores de acceso público.

- Incorporar revisiones periódicas de configuración (hardening) de servicios expuestos (Apache, Samba, SSH) como parte del mantenimiento regular.

6. Protocolo de contingencia

6.1 Escenario de falla

Un escaneo agresivo de puertos o un ataque de fuerza bruta sin límites de tasa contra los servicios SSH o Samba podría saturar el servicio o activar mecanismos de bloqueo automático, interrumpiendo el acceso legítimo de los administradores al servidor.

6.2 Impacto sobre la continuidad del negocio

Una interrupción de los servicios web, de archivos compartidos (Samba) o de acceso remoto (SSH) afectaría la operatoria diaria de INSECUR S.A. que depende de estos servicios, con una indisponibilidad estimada de entre 30 minutos y algunas horas según la causa y el método de recuperación disponible.

6.3 Plan de respuesta

1. Activación: monitoreo de servicios (alertas de caída) y reportes de usuarios sobre indisponibilidad.
2. Contención: aislar el servicio afectado, suspender tareas de red en curso y notificar al equipo técnico dentro de los primeros 15 minutos.
3. Recuperación: restaurar el servicio desde backup o mediante reinicio controlado; de persistir el problema, activar el servidor espejo si existe.
4. Comunicación: notificar a la dirección de INSECUR S.A. y, de corresponder, a los usuarios internos afectados.
5. Post-mortem: documentar la causa raíz, las acciones tomadas y las mejoras a implementar para evitar su repetición.

6.4 RTO y RPO estimados

RTO (Recovery Time Objective)	2 horas
RPO (Recovery Point Objective)	24 horas (último backup diario)

7. Anexos

Anexo A — Bitácora de comandos

Archivo	Fecha	Contenido
clase_01_20261005.txt	05/10/2026	Sala Pentesting Fundamentals (teórica) y conexión VPN
clase_02_20261007.txt	07/10/2026	Basic Pentesting completa: reconocimiento, explotación y escalada
basicpentesting_nmap_inicial.txt	07/10/2026	Escaneo inicial de puertos y servicios
basicpentesting_gobuster.txt	07/10/2026	Enumeración de directorios web
clase_03_20261007.txt	07/10/2026	Vulniversity completa: reconocimiento, explotación (webshell) y escalada a root
vulniversity_nmap_inicial.txt	07/10/2026	Escaneo inicial de puertos y servicios
vulniversity_gobuster_3333.txt	07/10/2026	Enumeración de directorios web (puerto 3333)
vulniversity_gobuster_internal.txt	07/10/2026	Enumeración de /internal/ (formulario de subida)

Anexo B — Capturas de pantalla

Nota: las capturas se conservan completas (sin recortar), ya que la cátedra pidió que se vea la fecha y hora del sistema Kali en cada una. El nombre de archivo es el que usé en mi propia carpeta de trabajo, no necesariamente el patrón formal usado en el resto del informe.

Archivo	Hallazgo	Qué demuestra
captura de completado pentesting fundamentals.png	—	Finalización de la sala teórica Pentesting Fundamentals
escaneo nmap.png	—	Escaneo inicial de puertos y servicios (nmap)
archivo staff.png	H-02	Contenido de staff.txt obtenido del share SMB "Anonymous"; revela el usuario "jan"
reconocimiento_H-02.png	H-02	Listado del share SMB "Anonymous" vía smbclient
password crackeado.png	H-03	Hydra encuentra la contraseña válida del usuario "jan"
reconocimiento_H-03.png	H-03	Confirmación de "jan" como usuario válido del sistema
howami id uname dentro al ingresar con ssh.png	H-03	whoami / id / uname tras el login SSH como "jan"

obtencion del password de jhon.png	H-05	John the Ripper obteniendo la passphrase de la clave SSH de "kay"
Contraseña del archivo pass.bak.png	H-05	Acceso como "kay" y contenido del archivo pass.bak
final del room y hash de la contraseña.png	H-05	Hash SHA-256 de la contraseña final del desafío
formulario de subida de archivos si restriccion de tipo.png	H-06	Formulario de subida en /internal/ sin validar el tipo de archivo
gobuster encontro directorio no destinado a ser publico room3.png	H-06	Gobuster descubre el directorio /internal/ en el puerto 3333
reverse shell obtenida.png	H-06	Reverse shell obtenida tras subir el webshell .phtml
flag de bill sacada del user.txt.png	H-06	user.txt de "bill" obtenido tras confirmar el RCE
flag de root.png	H-07	root.txt leído tras la escalada vía SUID en /bin/systemctl
roombasicpentesting completado.png	—	Finalización de la sala Basic Pentesting
vulniversity completo.png	—	Finalización de la sala Vulniversity

Anexo C — Hashes de las flags obtenidas

ID	Sala	SHA-256
H-03	Basic Pentesting	9eb6835cc95b053818b660bd9fc9f092a0b30cef89c1f0f17f469d5caa0ae617
Final	Basic Pentesting	3ffd53ec80858f9ddcd75d69102724ab1bc1020855fff924227f618c4bfccf57
user.txt	Vulniversity	d324bd433001e5bdfc39e04d794539c15b51982a5bf6fc78efea46369b7bf956
root.txt	Vulniversity	cfbc740435ad60030304080e35131ffcaf8ac5f71b65e002f5b546aa3cda7ce8

Anexo D — Declaración ética firmada

Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados y con fines exclusivamente académicos.

Firma del estudiante

Fecha

8. Fuentes y bibliografía

- TryHackMe. Pentesting Fundamentals. <https://tryhackme.com/room/pentestingfundamentals>
- TryHackMe. Basic Pentesting. <https://tryhackme.com/room/basicpentestingit>
- TryHackMe. Vulniversity. <https://tryhackme.com/room/vulniversity>
- OWASP Foundation. Web Security Testing Guide (WSTG). <https://owasp.org/www-project-web-security-testing-guide/>
- NIST (2008). Technical Guide to Information Security Testing and Assessment (SP 800-115).